



TECHNICAL PRODUCT DOCUMENTATION

Capability & Compliance Reference

The authoritative technical reference for VultSight Scope, an on-premises Vulnerability Assessment, External Attack Surface Management, and vulnerability-lifecycle management platform. This page is the published evidence source cited by the VultSight Scope Capability & Compliance Matrix.

On-premises & air-gap capable

One unified findings model

CVSS v4 · EPSS · KEV

Doc rev 2026-10-08

How to read this page. Each section documents a capability area and how VultSight Scope implements it. Items that depend on a deployment choice or a licensed content feed are called out explicitly in gold, so the reference stays accurate as a citation. This document describes product behaviour; it is not a certification statement.

01 Platform overview

VultSight Scope is a single platform for discovering assets, assessing them for vulnerabilities and misconfigurations across every surface, prioritizing by real-world risk, and tracking remediation to closure — all from one normalized findings model.

VultSight Scope's assessment modules — spanning web, API, network, host, cloud, containers, mobile, source code, device configuration and identity — report into one common findings schema. Findings are de-duplicated across modules, enriched with authoritative vulnerability intelligence, scored on a unified enterprise risk scale, and carried through a triage, re-scan and remediation-tracking lifecycle with SLA management and audit-grade reporting.

Architecture at a glance

Control plane

The console, API, orchestration, findings store and intelligence pipeline, backed by a relational datastore and an in-memory cache.

Scan nodes

Distributed, outbound-only appliances that reach internal and segmented networks and run assessments close to the targets. Mutual-TLS data channel; air-gap install.

Content service

Central, vendor-signed distribution of detection content and signed software releases. Two-hop: the control plane and each node independently verify the vendor signature.

Findings model

One normalized schema for every module, with stable fingerprint-based de-duplication and cross-module corroboration.

02 Deployment & architecture

VultSight Scope is software-only and ships as containers, deployable across physical, virtual and containerized environments on standard x86/ARM Linux hosts.

- **Editions.** A single codebase with feature parity. The edition flag selects **SaaS/MSP** (multi-client, hosted) or **Standalone appliance** (single organization, on-prem, offline signed licence).
- **Fully on-premises.** Core assessment runs with no mandatory cloud component and no inbound network access. Scan nodes and the control plane are outbound-only; secrets never leave the environment.
- **Primary + Disaster Recovery.** The console supports Primary/DR deployment via database streaming replication over TLS, with a documented failover/failback runbook and a live DR-readiness view (database role, replication lag, backup freshness).
- **Deployment footprint.** Industry-standard container runtime; a relational datastore and in-memory cache; the control plane runs as an on-host service, scan-node data channel on TCP 8443.

Air-gap: fully supported — vulnerability intelligence, detection content and software updates are all deliverable as single, digitally-signed files that are re-verified on import. A fully air-gapped site may skip the central content sync entirely.

03 Licensing

VultSight Scope is available under both **perpetual** and **annual-subscription** licensing models. The appliance edition validates an offline, cryptographically-signed licence locally — no phone-home is required.

04 Asset discovery & inventory

The VultSight Scope EASM Discovery Engine finds assets through active and passive techniques and keeps a de-duplicated, risk-classified inventory.

- **Passive recon (Phase 1).** Subdomain enumeration and live-host probing with technology, title and status fingerprinting.
- **Ownership gate.** Discovered hosts are staged with an ownership score (apex / subdomain-of-seed / unattributed) and only imported above a configurable threshold — discovery never auto-scans unowned space.
- **Cloud discovery (Phase 2).** Enumerates a connected cloud account (compute, managed databases, load balancers, storage, DNS) to surface managed services passive DNS cannot see.
- **Change tracking (Phase 3).** Each run is diffed against the previous (new / changed / gone), and scheduled discovery *watches* re-run on a cadence.
- **Active discovery.** Network discovery with intelligent, adaptive port scanning (timing controls) to optimize efficiency and limit network impact.
- **DHCP-based identification.** Lease ingestion (standard lease formats and CSV) with MAC-primary correlation — a device that changes IP stays one asset, with full IP-change history.
- **Classification & tagging.** Automatic classification and business-criticality scoring; asset tagging by business unit, application, owner, location, criticality and regulatory classification.
- **Scan-less (telemetry) identification.** EOL-software/OS and insecure-service findings are inferred from fingerprints already collected, with no active probe — supplementing conventional scanning.

Live cloud *discovery enumeration* currently targets AWS. Cloud security-posture assessment (see §5, Cloud Security Posture) covers AWS, Azure and GCP via credentialed checks.

05 Assessment-module coverage

Every assessment module implements a uniform run/normalize contract and reports into the same findings model. Named **scan profiles** bundle modules per intent (quick, web, network, full, container, cloud, api, mobile, config, compliance, tls, sca, sast, active-directory, virtualization).

Assessment module	Surface	What it does
Web Application (DAST)	Web	Authenticated and unauthenticated dynamic testing of web applications, including single-page/JS apps.
API Security	API	Scanning driven by OpenAPI/Swagger, GraphQL and SOAP/WSDL definitions, with bearer / api-key / basic auth.
Network & Host VA	Network / host	Service/version and OS detection with vulnerability checks; runs on the scan node for segmented networks; IPv6-safe.
Configuration & Compliance	Configuration	Authenticated CIS / SCAP / STIG benchmark audit; failed controls become findings with a pass/fail score.
Container Image	Containers	Image vulnerabilities across OS packages and application dependencies.
Software Composition (SCA)	Dependencies / IaC	Vulnerable dependencies from lockfiles, committed-secret detection, and infrastructure-as-code misconfiguration.
Static App Testing (SAST)	Source code	Static application security testing on cloned source (Git URL; token for private repositories).
Cloud Security Posture	Cloud	AWS / Azure / GCP CIS and best-practice posture checks using a read-only role.
Active Directory Security	Identity	Credentialed, read-only assessment of Active Directory security posture.
Virtualization	Virtualization	Credentialed cluster hardening for VMware ESXi, Hyper-V and Nutanix AHV (lockdown, encryption, version/EOL).
Mobile Application	Mobile (static)	Static analysis of Android (APK/AAB) and iOS (IPA) packages, mapped to OWASP MASVS/MASTG.

Assessment module	Surface	What it does
TLS/SSL Posture	TLS/SSL	Expiring certificates, weak ciphers, deprecated protocols and missing security headers.
Device Config Review	Device config	CIS-aligned hardening review of network-device running-configurations.
External Scanner Import	Import	Ingests third-party scanner results in industry-standard formats into the unified model (dedup, KEV/EPSS, scoring).
Scan-less Telemetry	Scan-less	Infers EOL / insecure-service findings from existing fingerprints with no active probe.

Platform coverage includes Windows, Linux, UNIX, network devices (firewalls, routers, switches, wireless controllers, VPN gateways, load balancers), databases, hypervisors (VMware ESXi, Hyper-V, Nutanix AHV), containers and Kubernetes/OpenShift, and storage/virtual appliances where credentialed access or feeds exist. Both **IPv4 and IPv6** are supported natively. Weak SSL/TLS configurations, deprecated protocols, insecure ciphers, certificate misconfigurations, default credentials and weak password policies are all detected.

Breadth: the 200,000+ plugin / 75,000+ CVE detection breadth is met through a licensed enterprise detection-content feed and/or import of a licensed external scanner's results, priced into the solution TCO (see §10).

06 Authenticated scanning

VultSight Scope performs both **authenticated (credentialed)** and **unauthenticated** assessments.

Authenticated scans yield configuration audit, patch state and far lower false-positive rates.

- Scanning credentials are encrypted at rest with **AES-256-GCM** (only ciphertext/IV/tag persisted; secrets are never logged).
- Optional **enterprise PAM integration** fetches privileged credentials at scan time — VultSight Scope stores only a reference, never the secret.
- Credentials are provisioned to distributed scan nodes over the mutual-TLS channel for the duration of a job only; nodes hold no standing privileged access and retain no plaintext.

07 Active Directory posture

The Active Directory Security module performs read-only, credentialed assessment of directory security posture:

- Kerberoasting and AS-REP roasting exposure
- Unconstrained delegation
- Weak account flags and password-policy weaknesses
- Machine-account quota
- Privileged-account review

08 Mobile application testing

The Mobile Application module performs **static** security analysis of Android (APK/AAB) and iOS (IPA) packages, with results mapped to **OWASP MASVS** and the **MASTG**. The target is an uploaded application artifact.

Mobile testing is static analysis; dynamic/device-based testing is not part of this module.

09 Configuration & compliance

Authenticated configuration assessment runs through the Configuration & Compliance and Device Config Review modules. Failed controls become findings with a pass/fail compliance score.

- Benchmarks: **CIS Benchmarks**, **SCAP**, **DISA STIG** (where feed-supported) and organization-defined baselines.
- Native compliance mapping to **PCI DSS v4.0**, **CIS** and **HIPAA** (keyed off CWE/KEV/CVE/keywords), rolled up into per-control pass/gap and a compliance report.

10 Vulnerability intelligence

Findings are enriched from authoritative, regularly-updated sources:

CVE metadata

Authoritative CVE metadata with CWE/CPE; CVSS **v2 / v3.0 / v3.1 / v4.0**, preferring the newest version and authoritative-primary metrics.

Exploitation signals

CISA **KEV** (observed), **EPSS** (likely), and public-exploit availability (published / weaponised).

Vendor advisories

Advisory intelligence to resolve the exact fix version for an installed dependency.

Lifecycle (EOL/EOS)

Lifecycle intelligence for operating systems, firmware, applications and databases.

Detection library

Network, web, container and dependency detection content, plus import of external scanner results that unifies additional coverage.

The **200,000+ plugin / 75,000+ CVE** breadth metric is met via a licensed enterprise detection-content feed and/or import of a licensed external scanner's results — both priced into the solution TCO.

11 Risk prioritization

Every finding carries a single **enterprise risk score** that correlates severity, real-world exploitation and asset importance:

```
# unified risk score
risk = base(CVSS×10 or severity weight)
      × exploitability
      × asset_criticality

exploitability = max( KEV 1.5, weaponised 1.4, public_exploit 1.3, EPSS 1.0–1.5 )
# added signals can only raise risk, never mask it
```

This yields predictive, exploitability-aware prioritization that surfaces the vulnerabilities most likely to be attacked on the assets that matter most.

12 Findings & remediation

- **One normalized model.** Every module reports into a single schema across network, host, server, endpoint, cloud, container, database, device-config and identity sources.
- **De-duplication.** A stable fingerprint — `hash(asset + canonical_key + normalized_location)` — collapses duplicates; cross-module corroboration is recorded in `seen_by_engines`.
- **False-positive management.** Cross-module de-duplication, advisory AI verdicts, suppression rules and a finding-status workflow: `new` → `confirmed` → `accepted_risk` → `resolved` → `false_positive` (FPs excluded from dashboards/reports by default).
- **Remediation validation.** Scheduled or on-demand re-scan produces a delta (persistent / newly-found / fixed) with full remediation history.
- **SLA management.** Per-severity due dates (default 15 / 30 / 60 / 90 days) with overdue/breach computation, a dashboard tile and an `sla_breach` alert sweep.
- **Trends.** Cross-cycle comparison (`first_seen/last_seen`) identifies newly-discovered, remediated, recurring and persistent findings, with asset-level remediation tracking and risk trends over time.

13 Reporting & dashboards

- **Dashboards.** Executive, operational, technical and compliance views with drill-down and customizable KPIs.
- **Formats.** HTML, PDF, XLSX and DOCX; report types include executive, operational, technical and compliance.
- **Digitally signed.** Stored reports are RSA-SHA256 signed and independently verifiable — `GET /reports/:id/verify` returns the signer certificate for third-party validation.
- **Password-protected export.** An AES-256 password-protected PDF export is available for compliance distribution.
- **White-label & approval.** Organization branding and configurable content, with a role-based maker-checker workflow: `draft` → `in_review` → `approved` → `released`, fully audited. Reports never name the underlying assessment tooling.
- **AI executive summary.** Optional AI-drafted summary that lands only on a draft report and requires manager approval before release.

Report *generation* is on-demand and API-driven; scheduling applies to scans and discovery watches. Digital signing is applied to the stored report; the password-protected PDF export is AES-encrypted rather than separately signed.

14 Authentication & RBAC

- **Local auth.** bcrypt password hashing with an HMAC-SHA256-signed session token in an httpOnly cookie (12h TTL).
- **MFA.** TOTP (RFC 6238), compatible with standard authenticator apps; the secret is vault-encrypted.
- **Enterprise SSO.** SAML 2.0 (SP-initiated, JIT provisioning, group→role), OpenID Connect (auth-code, JWKS verify, group claim→role), and LDAP / Active Directory bind (group→role).
- **RBAC.** Four roles (admin / manager / analyst / viewer) with an explicit capability map; the API is the enforcement point. Analysts and viewers are scoped to assigned engagements; the appliance edition is single-organization.
- **API keys.** SHA-256-hashed keys (Bearer or X-API-Key) resolve to a role-bearing principal.

15 Data security & cryptography

- **In transit.** Console/API TLS 1.3 is enforced at the deployment's TLS termination; the distributed scan-node data channel uses **mutual TLS** with an explicit, auditor-verifiable minimum-version floor.
- **At rest.** AES-256-GCM secret vault keyed from a script-derived key; only `iv:tag:ciphertext` is persisted and secrets are never logged.
- **Tamper-evident audit.** Append-only audit log with a database-computed hash chain (`entry_hash/prev_hash`). `GET /system/audit/verify` recomputes the chain and detects tampering or truncation; authorized purges are checkpointed and distinguished from a break.
- **Retention.** Configurable archive-before-delete per data class (default retain-forever); audit purges are checkpointed.
- **Tenancy.** Logical multi-tenancy with per-engagement access control enforced in the application layer and on every tenant-scoped query.

FIPS 140-2 / 140-3: achieved by deploying on a FIPS-mode host with a CMVP-validated cryptographic module — a deployment configuration, not a product certification.

16 Detection content & updates

- **Regular updates.** Network, web and container detection content and vulnerability intelligence (KEV/EPSS/CVE) are refreshed on a daily schedule.
- **Signed distribution.** VultSight Scope signs each content bundle; the control plane and every scan node **independently** verify the vendor signature — a two-hop model in which nodes never trust the relay.

- **Air-gap.** Offline, digitally-signed detection and software updates import from carried-in media and are re-verified on the node.
-

17 Distributed scan nodes

Scan nodes extend assessment into internal and segmented networks while keeping the architecture outbound-only.

- **Enrollment.** A bearer enrollment token issues a per-node client certificate.
 - **Data channel.** Mutual-TLS on TCP 8443, keyed by certificate fingerprint. Nodes *pull* jobs and *post* results; credentials are fetched per job.
 - **Air-gap install.** Nodes install from a signed package (not published to a public registry by design).
 - **Fleet visibility.** A global node-status view with offline alerting; the node content mirror re-serves the signed bundle to downstream nodes over mutual TLS.
-

18 Integrations & APIs

- **REST API.** Secure REST endpoints with API-key authentication (Bearer / X-API-Key) for automation and integration.
 - **Notifications.** An event dispatcher fans out to webhook, chat, email and RFC 5424 syslog — events include scan_complete, critical_finding, schedule_miss, node_offline, backup_failed, feed_stale, disk_low and sla_breach.
 - **SIEM / SOAR / TIP / NAC / CMDB.** Integrated via REST API, webhooks and RFC 5424 syslog (SIEM via syslog forwarding of findings and audit events).
 - **ITSM.** Native ITSM integration (OAuth 2.0): incident auto-created on confirm/rule, updated on triage, and auto-resolved on re-scan validation, with finding-to-ticket linkage; additional platforms via webhook.
 - **PAM.** Enterprise PAM integration for authenticated-scan credentials (see §6).
-

VultSight Scope — Capability & Compliance Reference. Technical product documentation, revision 2026-10-08. This page is the evidence source cited by the VultSight Scope Capability & Compliance Matrix. Capability descriptions reflect product behaviour; deployment-dependent and feed/licence-dependent items are noted inline.